

Performance Task

Web Application Attacks

Objective:

At the end of the exercise, the students should be able to:

- Simulate a web application attack to compromise the security of web applications to steal sensitive information.

Requirements:

- Internet connection
- EC-Council lab access

Procedure: (100 points)

1. Sign in to your EC-Council lab account at <https://eccouncil.learnondemand.net/>
2. Open the **Ethical Hacking Essentials** course.
3. Launch the **Web Application Attacks and Countermeasures** lab.
4. Click Next until you go to **Lab 2: Perform a Web Application Attack to Compromise the Security of Web Applications to Steal Sensitive Information**

Task 1: Perform Parameter Tampering using Burp Site

A web parameter tampering attack involves the manipulation of parameters exchanged between the client and server to modify application data such as user credentials and permissions, price, and quantity of products.

Here, we will use the Burp Suite tool to perform parameter tampering.

In this task, the target website (**www.moviescope.com**) is hosted by the victim machine, **Windows Server 2019**. Here, the host machine is the **Parrot Security** machine.

1. In **Parrot Security** machine click the **Firefox** icon from the top section of **Desktop** to launch the **Mozilla Firefox** browser.
2. The **Mozilla Firefox** window appears; type **http://www.moviescope.com** into the address bar and press **Enter**.
3. Now, set up a **Burp Suite** proxy by first configuring the proxy settings of the browser.
4. In the **Mozilla Firefox** browser, click the **Open menu** icon in the right corner of the menu bar and select **Settings** from the list.
5. The **General** settings tab appears. In the **Find in Settings** search bar, type **proxy**, and press **Enter**.
6. The **Search Results** appear. Click the **Settings** button under the **Network Settings** option.
7. A **Connection Settings** window appears. Select the **Manual proxy configuration** radio button and specify the HTTP Proxy as **127.0.0.1** and the Port as **8080**. Tick the **Also use this proxy for HTTPS** checkbox and click **OK**. Close the Settings tab and minimize the browser window.
8. Click the **Applications** menu from the top left corner of **Desktop**, and navigate to **Pentesting --> Web Application Analysis --> Web Application Proxies --> burpsuite** to launch the **Burp Suite** application.
9. A security pop-up appears, enter the password as **toor** in the **Password** field and click **OK**.
10. In the next **Burp Suite Community Edition** notification, click **OK**.

If Terms and Conditions window appears click on **I Accept**

11. **Burp Suite** initializes. If a **Burp Suite Community Edition** notification saying **An update is available** appears, click **Close**.

12. The **Burp Suite** main window appears; ensure that the **Temporary project** radio button is selected and click the **Next** button. Provide a screenshot of this.

If an update window appears, click **Close**.

13. In the next window, select the **Use Burp defaults** radio-button and click the **Start Burp** button.

14. The **Burp Suite** main window appears; click the **Proxy** tab from the available options in the top section of the window.

15. In the **Proxy** settings, by default, the **Intercept** tab opens-up. Observe that by default, the interception is active as the button says **Intercept is on**. Leave it running.

Turn the interception on if it is off.

16. Switch back to the browser window, and on the login page of the target website (**www.moviescope.com**), enter the credentials **sam** and **test**. Click the **Login** button.

Here, we are logging in as a registered user on the website.

17. Switch back to the **Burp Suite** window and observe that the HTTP request was intercepted by the application.

You can observe that the entered login credentials were intercepted by the Burp Suite.

18. Now, keep clicking the **Forward** button until you are logged into the user account.

19. Switch to the browser, and observe that you are now logged into the user account. Provide a screenshot of this.

20. Now, click the **View Profile** tab from the menu bar to view the user information.

21. After clicking the **View Profile** tab, switch back to the **Burp Suite** window and keep clicking the **Forward** button until you get the HTTP request, as shown in the screenshot.

22. Now, navigate to the **Params** tab under the **Intercept** tab to view the captured parameters.

23. Under the **Params** tab, observe a table with captured values such as **URL** and **Cookie**.

24. In the **URL** type with the name **id**, double-click the **Value** column to change it from **1** to **2**. Provide a screenshot of this.

25. After changing the value, navigate back to the **Raw** tab.

26. In the **Raw** tab, click the **Intercept is on** button to turn off the interception.

27. After switching off the interception, navigate back to the browser window and observe that the user account associated with **ID=2** appears with the name **John**. Provide a screenshot of this.

Although we logged in using sam as a username with ID=1, using Burp Suite, we successfully tampered with the ID parameter to obtain information about other user accounts.

28. Similarly, you can edit the **id** parameter in Burp Suite with any random numeric value to view information about other user accounts.

29. Switch to the browser window and perform Steps **4-6**. Remove the browser proxy set up in **Step 7**, by selecting the **No proxy** radio button in the Connection Settings window and clicking **OK**.

30. Close all open windows and document all the acquired information.

31. Compile your screenshots in MS Word.

32. Let your instructor check your progress before submitting a PDF copy on eLMS.

GRADING RUBRIC:

Criteria	Excellent (5)	Satisfactory (4)	Needs Improvement (2)	Unsatisfactory (1)	Points
Environment Setup (×5)	Successfully prepared and accessed the environment without errors; ready to perform the task.	Minor setup or access issues, but eventually ready to proceed.	Repeated setup difficulties requiring intervention or partial completion .	Failed to access or prepare the environment.	___/25
Target Discovery & Verification (×5)	Correctly discovered the target, verified that the service was active, and clearly documented results.	Discovered target with minor process or documentation issues.	Partial or incorrect discovery with minimal verification.	Did not perform discovery or verification.	___/25
Attack Execution & Access Validation (×5)	Successfully executed attack, obtained valid credentials, gained access, and performed required follow-up actions; documented evidence clearly.	Executed an attack and accessed the system with minor errors or incomplete documentation.	Attempted execution, but results are incomplete, incorrect, or partially validated.	Did not execute an attack or validate access.	___/25
Procedure Following and Documentation (×5)	Followed all steps in logical order; compiled all screenshots and documented key findings and process steps in Word	Followed most steps; screenshots compiled with some procedural or documentation gaps	Some steps are missing or out of order; documentation is unclear or weak	Major steps missed or out of order; documentation absent or incoherent	___/25
TOTAL SCORE					___/100